實作過程 (在 cscode 的終端機和 vscode 操作):

1. **下載專案**：使用 Git 下載老師提供的原始檔案
   git clone https://github.com/pyc6666/mini-login-student.git
   cd mini-login-student

2. **建立虛擬環境**：為了讓 Python 獨立執行，不影響電腦其他設定
   python -m venv venv
   .\venv\Scripts\activate

3. **安裝工具**：安裝專案運作需要的套件
   pip install -r requirements.txt

4. **初始化資料庫**：建立存放使用者資料的檔案。
   python db_init.py

5. **修補前行為**：輸入 ' OR '1'='1 即可繞過密碼檢查，成功登入系統並取得權限。
   漏洞成因：原始程式直接將使用者輸入的字串拼接到 SQL 指令中，導致惡意指令被資料庫執行。
   修補方式：改用「參數化查詢」，以 ? 作為佔位符 。
   修補後驗證結果：同樣輸入 ' OR '1'='1，系統會回傳 {"login":"fail"}，證明惡意指令已被擋下，無法繞過登入。

```
sql = "SELECT role FROM users WHERE username=? AND password=?"
row = q_one_params(sql, (username, password))

if row:
    return jsonify({"login": "ok", "owner": OWNER, "role": row[0]}), 200
return jsonify({"login": "fail", "owner": OWNER}), 401
```

6. **修補前行為**：在留言板輸入 <script>alert('XSS')</script>，網頁會直接執行該腳本並彈出警示視窗。

   漏洞成因：系統未對使用者的留言進行轉義就直接輸出在網頁 HTML 中，使瀏覽器誤將留言當成程式碼執行。

   修補方式：在輸出留言前調用 html.escape() 函式處理特殊字元 。

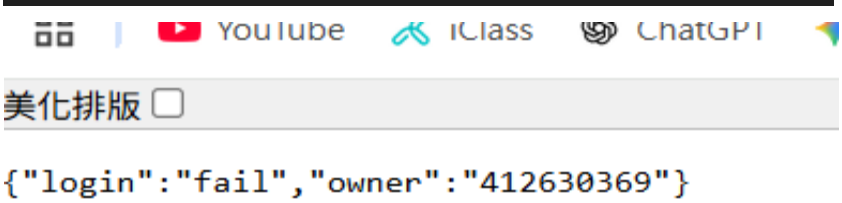
   修補後驗證結果：輸入測試腳本後，網頁僅會顯示原始碼文字，不會執行任何程式或彈窗。

```
page = "<h2>Comments</h2><ul>"
for c in COMMENTS:
    safe = html.escape(c)
    page += f"<li>{safe}</li>"
page += "</ul>"
```

7. **實作內容**：修改 app.py 與 docker-compose.yml 中的 OWNER 為個人學號，並將 MODE 改為 patched 。

   驗證結果：透過存取 /health 頁面，確認系統顯示修補完成狀態（version: patched）且正確識別開發者學號 。

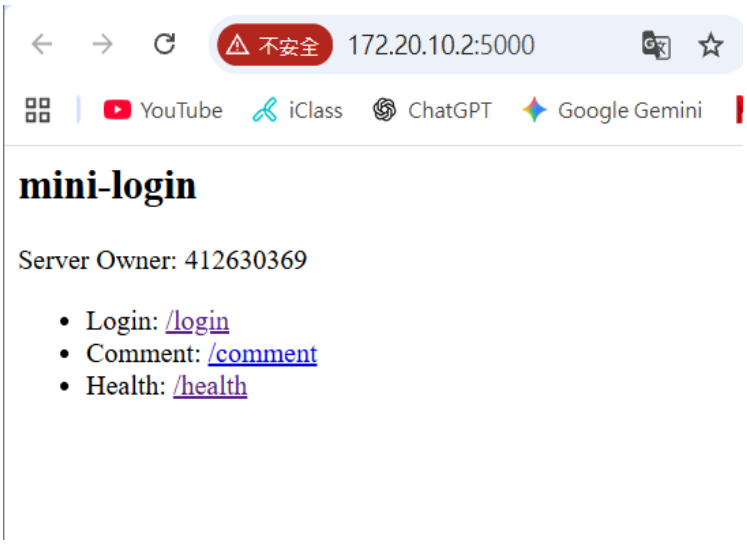
```
APP = Flask(__name__)
OWNER = os.getenv("OWNER", "412630369")
MODE = "patched"
DB = "users.db"
```



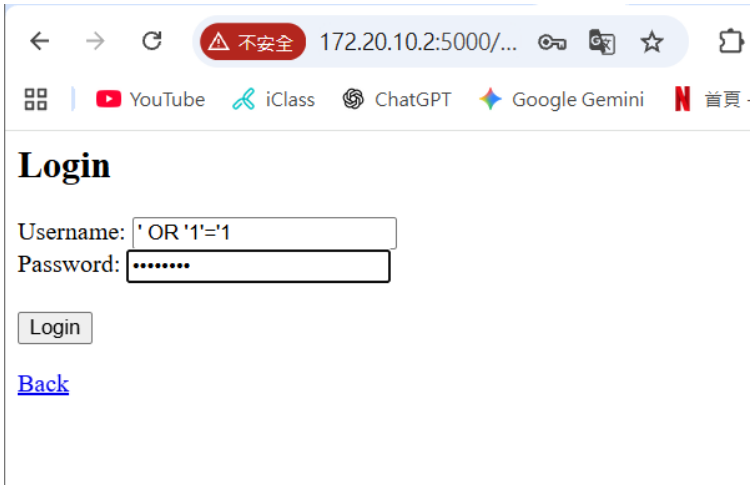
8. 將 container_name 與 environment 中的 OWNER 值改為學號

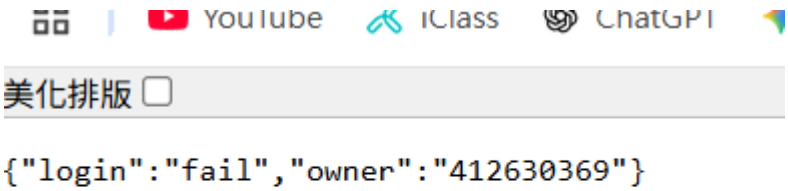
```
container_name: mini_login_412630369
environment:
  # TODO: 改成你的學號
  - OWNER=412630369
  - MODE=vuln
```

9. 結果：

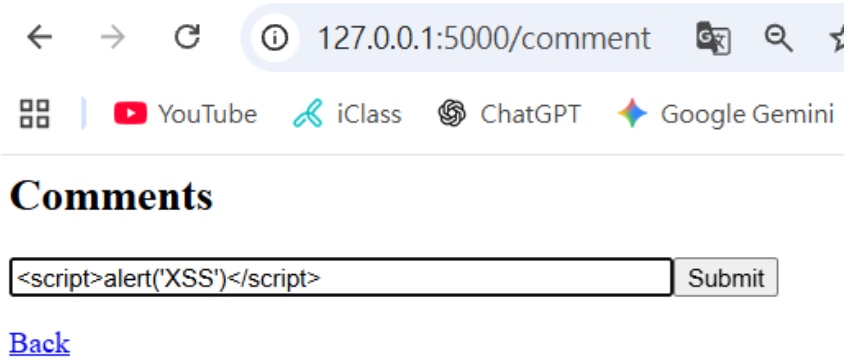

不安全
172.20.10.2:5000
YouTube
iClass
ChatGPT
Google Gemini
mini-login
Server Owner: 412630369
Login: /login
Comment: /comment
Health: /health

10.

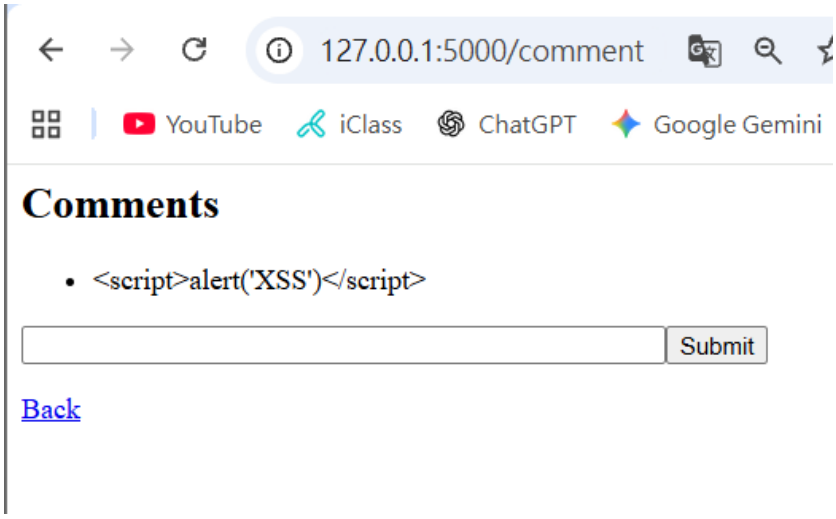

不安全
172.20.10.2:5000/...
YouTube
iClass
ChatGPT
Google Gemini
首頁
Login
Username: ' OR '1'='1
Password: ••••••••
Login
Back


YouTube
iClass
ChatGPT
美化排版
{"login":"fail","owner":"412630369"}

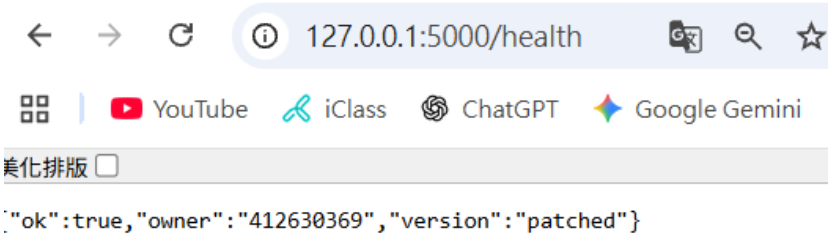
11.


127.0.0.1:5000/comment
YouTube
iClass
ChatGPT
Google Gemini
Comments
<script>alert('XSS')</script>
Submit
Back

12.


127.0.0.1:5000/comment
YouTube
iClass
ChatGPT
Google Gemini
Comments
<script>alert('XSS')</script>
Submit
Back

13.


127.0.0.1:5000/health
YouTube
iClass
ChatGPT
Google Gemini
美化排版
"ok":true,"owner":"412630369","version":"patched"}

14.